

JuiceShop_VAPT_Report.md

OWASP Juice Shop VAPT Assessment Report

Project Title

OWASP Juice Shop Web Application Security Assessment Using Burp Suite

Introduction

This project involved performing a web application vulnerability assessment on OWASP Juice Shop using Burp Suite within a controlled local lab environment.

The assessment focused on:

- Authentication analysis
 - JWT security analysis
 - API security testing
 - Access control validation
 - IDOR testing
 - HTTP security header analysis
 - OWASP Top 10 vulnerability mapping
-

Objective

The objective of this project was to analyze application traffic, identify potential security weaknesses, test authorization mechanisms, and evaluate security configurations using standard VAPT methodologies.

Scope

The assessment was conducted entirely within a locally hosted OWASP Juice Shop environment.

The following components were tested:

- Login functionality
- JWT authentication
- Basket APIs
- Order APIs

- User APIs
 - Administrative APIs
 - HTTP response headers
-

Tools & Technologies Used

- OWASP Juice Shop
 - Burp Suite Community Edition
 - JWT.io
 - Kali Linux
 - Chromium Browser
 - HTTP/JSON APIs
-

Methodology

1. Traffic Interception & Analysis

Burp Suite proxy interception was configured to capture HTTP requests and responses generated during:

- User login
- Registration
- Basket operations
- Product browsing
- Order requests
- User profile access

HTTP traffic was analyzed using:

- HTTP History
 - Repeater
 - Request/Response inspection
-

2. Authentication Analysis

Authentication traffic was analyzed by capturing requests sent to:

/rest/user/login

Example Captured Request

```
{ "email": "admin@juice-sh.op", "password": "admin123" }
```

Observation

Sensitive authentication credentials were visible in plaintext within the request body.

Security Impact

If transmitted insecurely in production environments, attackers may intercept and reuse user credentials.

OWASP Mapping

A02:2021 – Cryptographic Failures

3. JWT Token Analysis

JWT authentication tokens were captured from successful login responses and decoded using JWT.io.

Observed JWT Claims

- Email address
- User role
- Internal user ID
- Password hash
- Account metadata

Example JWT Response

```
{ "authentication":{ "token":"eyJ..." } }
```

Security Findings

- Sensitive information disclosure
- Administrative role exposure
- Password hash disclosure inside JWT payload

Security Impact

Attackers obtaining JWT tokens may enumerate privileged users and analyze authorization structures.

OWASP Mapping

A02:2021 – Cryptographic Failures

4. API Security Testing

Authenticated API endpoints tested:

- /rest/user/whoami
- /api/Users
- /api/BasketItems
- /api/Orders
- /rest/admin
- /api/Feedbacks

Testing activities included:

- Authorization validation
- User enumeration testing
- Access control verification
- Authenticated request replay

Security Observations

- User information disclosure
- Potential excessive data exposure
- Authorization validation testing

OWASP Mapping

A01:2021 – Broken Access Control

5. IDOR Testing

Insecure Direct Object Reference (IDOR) testing was performed by modifying object identifiers such as:

- BasketId
- OrderId

Example

Original Request:

```
{ "BasketId":1 }
```

Modified Request:

```
{ "BasketId":2 }
```

Objective

To evaluate whether unauthorized resources could be accessed through object identifier manipulation.

OWASP Mapping

A01:2021 – Broken Access Control

6. JWT Signature Validation Testing

JWT tampering validation was performed by modifying decoded token payload values and replaying altered JWTs.

Observation

Modified JWTs were rejected by the application, indicating that JWT signature verification protections were functioning correctly.

Security Impact

Proper JWT signature verification reduces the risk of unauthorized token forgery and privilege escalation.

7. HTTP Security Header Assessment

HTTP response headers were analyzed for recommended security protections.

Observed Headers

- X-Frame-Options
- X-Content-Type-Options

Missing Headers

- Content-Security-Policy
- Strict-Transport-Security
- X-XSS-Protection

Security Observation

Incomplete HTTP security hardening configuration was observed.

OWASP Mapping

A05:2021 – Security Misconfiguration

Key Findings Summary

Finding	Severity
Plaintext credential exposure	Medium
JWT information disclosure	Medium
Password hash exposure	High
User enumeration possibilities	Medium
IDOR testing through Basket IDs	High
Missing security headers	Low

Skills Demonstrated

- Web Application Penetration Testing
 - Burp Suite Traffic Analysis
 - JWT Security Assessment
 - API Security Testing
 - Access Control Testing
 - HTTP Request Manipulation
 - OWASP Top 10 Mapping
 - Security Header Analysis
 - Vulnerability Documentation
-

Conclusion

The project successfully demonstrated a structured VAPT workflow against OWASP Juice Shop in a controlled local environment. Multiple authentication, authorization, API security, and configuration-related observations were identified and mapped against OWASP Top 10 vulnerability categories.

The assessment also demonstrated practical experience with:

- Burp Suite traffic interception
 - JWT analysis
 - Repeater-based request manipulation
 - API authorization testing
 - Security configuration assessment
-

Disclaimer

This assessment was conducted entirely within a locally hosted OWASP Juice Shop lab environment for educational and authorized security testing purposes only.